

crypto-sources

Crypto Suite Source Registry

This document tracks the authoritative sources behind every check in the crypto suite (P-301..P-360). When a source publishes a new version (OWASP Smart Contract Top 10 2026, CCSS v10, NIST FIPS 207, MiCA Level 2 RTS, etc.), the maintainer reviews each affected check and either bumps its version, updates patterns, or supersedes it with a new check.

The format is: source, current version pinned in checks, URL, and the list of checks that reference it. Maintainers should re-verify each listed source quarterly and on-demand whenever a new version is announced.

Smart contract security frameworks

OWASP Smart Contract Top 10 (2025) — current version pinned in checks, published 2025 by OWASP Foundation. Tracks attack categories ranked by 2025 financial losses (Access Control \$953M leads, followed by Logic Errors, Reentrancy, Flash Loan Attacks, Input Validation, Oracle Manipulation, Unchecked External Calls, etc.). Source: <https://scs.owasp.org/sctop10/>. Methodology and underlying incident data: <https://github.com/OWASP/www-project-smart-contract-top-10>. Also referenced via <https://owasp.org/www-project-smart-contract-top-10/>. Affected checks: P-301, P-302, P-303, P-304, P-305, P-306, P-307, P-308, P-310, P-348, P-349, P-350, P-351, P-352, P-353, P-356, P-357.

Smart Contract Weakness Classification (SWC) Registry — Useful as secondary reference for Solidity-specific vulnerability categories. Source: <https://swcregistry.io/>.

Trail of Bits Building Secure Contracts — Practitioner guide for Solidity development discipline. Source: <https://github.com/crytic/building-secure-contracts>.

ConsenSys Smart Contract Best Practices — Long-standing guide, useful for cross-checking patterns and edge cases. Source: <https://consensys.github.io/smart-contract-best-practices/>.

Immunefi Vulnerability Severity Classification System v2.3 — Bug-bounty severity standard widely used by DeFi protocols; cited in check `severity` fields. Source: <https://immunefi.com/immunefi-vulnerability-severity-classification-system-v2-3/>.

Crypto custody standards

CryptoCurrency Security Standard (CCSS) v9.0 — Published December 17, 2024 by the CryptoCurrency Certification Consortium (C4). Three levels (1, 2, 3) covering key generation, storage, usage, holder grant/revoke, and key compromise. Source:

<https://cryptoconsortium.org/cryptocurrency-security-standard-documentation/details/>. Index:

<https://cryptoconsortium.org/standards-2/>. GitHub canonical:

<https://github.com/CryptoConsortium/CCSS>. Affected checks: P-311 through P-320, P-344, P-345, P-354, P-358.

NIST frameworks

NIST Cybersecurity Framework 2.0 — Latest revision; Govern, Identify, Protect, Detect, Respond, Recover function families. Source: <https://www.nist.gov/cyberframework>. Affected checks: many across custody, transaction safety, and incident response groups.

NIST FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA) — Post-quantum cryptography standards finalized August 2024. Source: <https://csrc.nist.gov/projects/cryptographic-standards-and-guidelines>. FIPS 203 specific: <https://csrc.nist.gov/pubs/fips/203/final>. Affected checks: P-360.

NIST Secure Software Development Framework (SSDF) v1.1 — Source:

<https://csrc.nist.gov/projects/ssdf>. Affected checks: P-301.

NIST Special Publication 800-57 — Key Management Recommendations. Source:

<https://csrc.nist.gov/pubs/sp/800/57/pt1/r5/final>. Affected checks: P-319.

Anti-money-laundering and sanctions

FATF Recommendations (2023, current) — International AML/CFT standards, including Recommendation 16 (Travel Rule for VASPs) and Recommendation 6 (sanctions). Source: <https://www.fatf-gafi.org/en/publications/Fatfrecommendations/Fatf-recommendations.html>. Affected checks: P-322, P-323, P-324, P-327, P-328, P-335, P-336.

OFAC Specially Designated Nationals (SDN) List — Continuously updated. The list itself is the authority; consult the live feed. Source: <https://ofac.treasury.gov/specially-designated-nationals-and-blocked-persons-list-sdn-human-readable-lists>. Affected checks: P-323, P-324, P-327, P-328, P-336.

FinCEN 31 CFR Chapter X — US BSA/AML regulations applicable to money transmitters and crypto businesses. Travel Rule: <https://www.ecfr.gov/current/title-31/subtitle-B/chapter-X/part-1010/subpart-D/section-1010.410>. Affected checks: P-323, P-328, P-336.

EU regulations

MiCA (Markets in Crypto-Assets Regulation, EU 2023/1114) — Full applicability December 30, 2024 with member-state transition until July 2026. Source: <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/markets-crypto-assets-regulation-mica>. ESMA RTS / ITS publications: <https://www.esma.europa.eu/policy-activities/crypto-assets>. Affected checks: P-316, P-320, P-322, P-328, P-358.

EU Transfer of Funds Regulation (TFR, 2023/1113) — Extends FATF Travel Rule into EU law. Source: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32023R1113>. Affected checks: P-328.

EU PSD2 (Directive 2015/2366) — Strong Customer Authentication requirements. Source: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32015L2366>. Affected checks: P-330.

Industry standards

OWASP API Security Top 10 (2023) — Source: <https://owasp.org/API-Security/editions/2023/en/0x11-t10/>. Affected checks: P-311, P-318, P-321, P-326, P-338.

OWASP Mobile Application Security Verification Standard (MASVS) 2.0 — Source: <https://mas.owasp.org/MASVS/>. Affected checks: P-342, P-344, P-355.

ISO/IEC 27001:2022 — Information Security Management Systems requirements with Annex A controls. Source: <https://www.iso.org/standard/27001>. Affected checks: P-312, P-313, P-315, P-318, P-319, P-320, P-322, P-329, P-330.

PCI-DSS v4.0 — Payment Card Industry Data Security Standard. Source: https://www.pcisecuritystandards.org/document_library/. Affected checks: P-311, P-313, P-318, P-319, P-344.

SOC 2 Trust Services Criteria (2017) — AICPA Trust Services Criteria for security, availability, processing integrity, confidentiality, and privacy. Source: <https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>. Affected checks: P-317.

Reference incidents and analyses

The 2025 incident lessons that informed several checks come from post-mortem analyses across multiple sources. Maintainers consult these when major incidents occur to identify new attack patterns warranting new checks.

Bybit Hack (February 2025, \$1.4B) — Cold-to-hot signing-interface replacement attack; major source for P-354, P-355. Coverage: <https://blog.amberdata.io/defis-year-of-exploits-2b-lost-lessons-learned>, <https://www.cryptopacthub.com/defi-exploits-2025-a-record-breaking-year-of-sophisticated-attacks-and-hard-won-lessons/>.

Cetus Hack (May 2025, ~\$220M) — Integer overflow in concentrated liquidity math; reinforces P-302, P-352. Coverage: <https://www.halborn.com/reports/top-100-defi-hacks-2025>.

GMX Hack (July 2025) — Flash loan attack; source for P-352. Same references.

Balancer Hack (November 2025) — Mathematical rounding bug. Same references.

Wormhole Bridge (\$320M, Feb 2022) — Source for P-308 and P-348 (uninitialized proxy / signature verification on bridge messages).

Nomad Bridge (\$190M, Aug 2022) — Source for P-308.

Tornado Cash OFAC sanctions (August 2022), Sinbad sanctions (November 2023) — Source for P-327.

Update procedure

When a referenced source publishes a new version, perform this checklist:

1. Read the diff (changelog, RFC, comparison documents).
2. List all checks in this document mapped to the source.
3. For each affected check, decide: bump version (small additions), add new patterns (new categories), supersede with new check (significant restructure), or leave unchanged (cosmetic updates).
4. Update the `version` and `frameworks` fields in affected check metadata blocks.
5. Re-test against the test fixture corpus.
6. Update CHANGELOG.md and this document with the new version pin.
7. Tag a new minor or patch release per semver discipline.

The framework version field in metadata uses `Framework:Version:Control` format (e.g., `OWASP-SC-Top-10:2025:SC01`) specifically so the runner's `--framework` flag can scope to a particular vintage of any framework, and so a future framework upgrade leaves prior `frameworks` declarations intact for historical audit comparability.